



CUERPO SUPERIOR DE SISTEMAS Y TECNOLOGÍAS DE LA INFORMACIÓN DE LA ADMINISTRACIÓN DEL ESTADO

T.80 Identificación y firma electrónica (1) Marco europeo y nacional. Certificados digitales. Claves privadas, públicas y concertadas. Formatos de firma electrónica.

Formatos de firma electrónica. XADES, CADES, PADES - Firma Longeva.

Índice del tema

1. XML DSIG.....	2
1.1. ELEMENTOS DE XML SIGNATURE	2
1.2. ESCENARIOS DE UTILIZACIÓN DE LA FIRMA DIGITAL EN XML	5
2. XADES.....	5
PERFILES:.....	6
2.1. VALIDACIÓN FIRMA XADES.....	10
2.2. VALIDACIÓN FIRMA XADES-A.....	12
3. EJEMPLOS FIRMA Y CIFRADO	13
4. WS-SECURITY	14
WS-Security	17
5. ALGORITMOS SIMÉTRICOS DE BLOQUES.....	20
Table 1: Security of some selected proposals	20
The notation of the table:	21

1. XML DSIG

Firma XML (también llamado XMLDSig, DSig-XML, XML-SIG) es una recomendación W3C que define una sintaxis XML para la firma digital. Funcionalmente, que tiene mucho en común con PKCS # 7, pero es más extensible y orientada hacia la firma de documentos XML. Es utilizado por diversas tecnologías Web: SOAP, SAML, etc..

La Firma XML se puede utilizar para firmar datos -recursos- de cualquier tipo, por lo general, los documentos XML, cualquier recurso accesible a través de una URL puede ser firmado.

Una firma XML utilizado para firmar un recurso fuera del documento XML que contiene se llama una firma **detached**, si se utiliza para firmar algunas de las partes que contiene el documento, se llama una firma **enveloped**; si contiene los datos firmados en sí mismo se llama firma **enveloping**.

El estándar XMLDSig recoge las reglas básicas de creación y procesamiento de firmas electrónicas de documentos XML.

Las firmas digitales XML (XMLDSIG) son firmas digitales diseñadas para su uso en transacciones XML. El estándar define un esquema para capturar el resultado de la firma digital aplicada a datos arbitrarios (a menudo en XML).

1.1. Elementos de XML Signature

- Elemento Signature
 - Encapsula la firma digital.
- Elemento SignedInfo
 - Contiene la información necesaria para la creación y validación de la firma.
- Elemento CanonicalizationMethod
 - Especifica el algoritmo de transformación canónica aplicado al código XML de SignedInfo antes de realizar el cálculo de su firma digital.
- Elemento SignatureMethod
 - Referencia al algoritmo utilizado para el cálculo del valor de la firma digital.
- Elemento Reference
 - Referencia a la información o documento que se encuentra firmado. Contiene Transforms, DigestMethod y DigestValue.
- Elemento SignatureValue
 - Contiene el valor de la Firma Digital.
- Elemento KeyInfo
 - Elemento opcional que permite a los receptores del mensaje obtener datos del certificado, como clave pública...
- Elemento Object
 - Elemento opcional que permite añadir información a la firma, por ejemplo, los datos que se van a firmar.

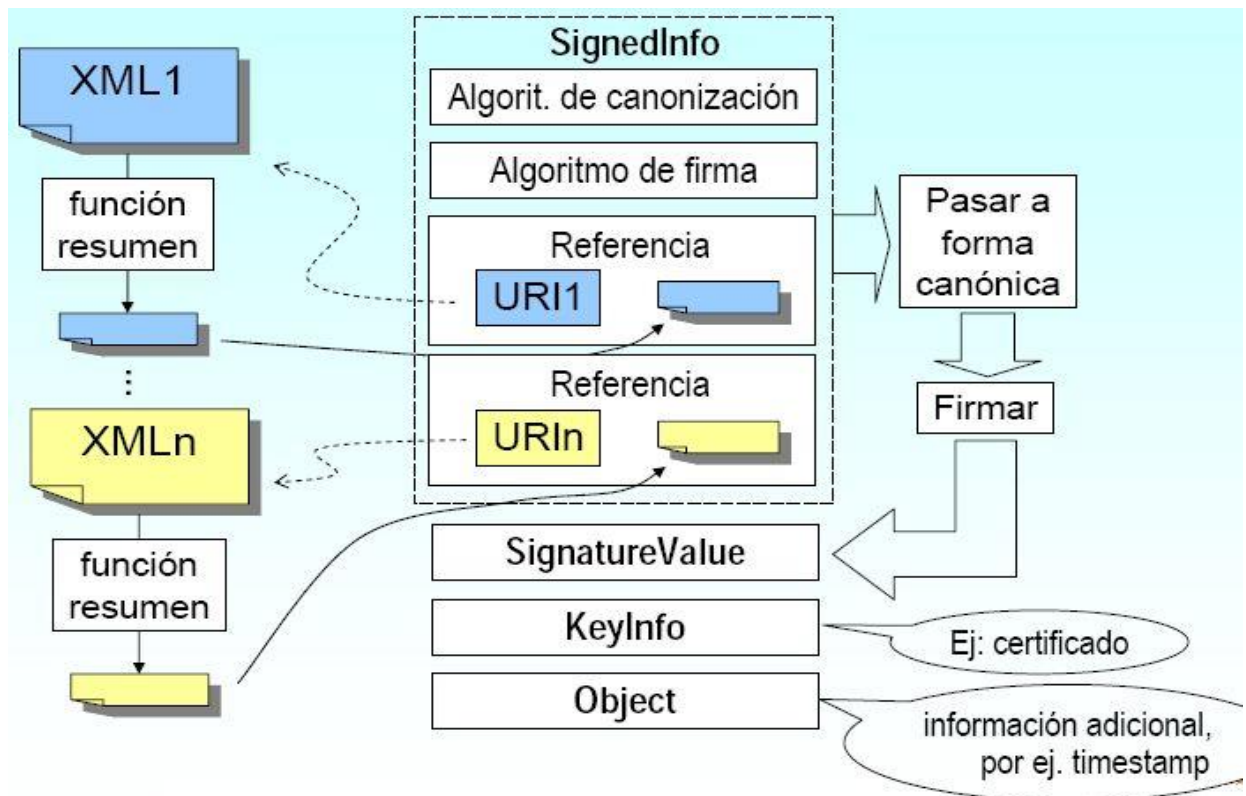


Figura 1.- Elementos constitutivos de la firma XML Dsig

```
<?xml version="1.0" encoding="UTF-8"?>
<Signature xmlns="http://www.w3.org/2000/09/xmldsig#">
  <SignedInfo Id="ejemplo">
    <CanonicalizationMethod Algorithm=
      "http://www.w3.org/TR/2001/REC-xml-c14n-20010315"/>
    <SignatureMethod Algorithm=
      "http://www.w3.org/2000/09/xmldsig#dsa-sha1" />
    <Reference URI="http://www.empresax.com/index.htm">
      <DigestMethod Algorithm=
        "http://www.w3.org/2000/09/xmldsig#sha1" />
      <DigestValue>j6lwx3rvEPO0vKtMup4NbeVu8nk=</DigestValue>
    </Reference>
    <Reference URI="http://www.empresax.com/pedido.xml#sender">
      <DigestMethod Algorithm=
        "http://www.w3.org/2000/09/xmldsig#sha1"/>
      <DigestValue>UrXLDLBIta6skoV5/A8Q38GEw44=</DigestValue>
    </Reference>
  </SignedInfo>
  <SignatureValue>
  </SignatureValue>
  <KeyInfo>
  </KeyInfo>
  <Object>
  </Object>
</Signature>
```

resúmenes de los recursos a firmar

parte del doc

Figura 2.- Resúmenes de los recursos a firmar, sendo estos recursos accesibles por una URI



Figura 3.- Elemento firmado SignedInfo, la Firma Signaturevalue, y el certificado usado KeyInfo

La siguiente figura muestra una firma completa, con todos los parámetros, indicados en el punto 1.1

```

<?xml version="1.0" encoding="UTF-8" ?>
- <soapenv:Envelope xmlns:ds="http://www.w3.org/2000/09/xmldsig#" xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
  xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
- <soapenv:Header>
- <ds:Signature>
- <ds:SignedInfo>
  <ds:CanonicalizationMethod Algorithm="http://www.w3.org/TR/2001/REC-xml-c14n-20010315" />
  <ds:SignatureMethod Algorithm="http://www.w3.org/2000/09/xmldsig#rsa-sha1" />          Metodo de Firma : SHA1withRSAEncryption
- <ds:Reference URI="#MsgBody">
- <ds:Transforms>
  <ds:Transform Algorithm="http://www.w3.org/2001/10/xml-exc-c14n#" />
  <ds:Transform Algorithm="http://www.w3.org/2000/09/xmldsig#enveloped-signature" />          Tipo de Firma : ENVELOPED
</ds:Transforms>
  <ds:DigestMethod Algorithm="http://www.w3.org/2000/09/xmldsig#sha1" />          Algoritmo de HUELLA
  <ds:DigestValue>1XtE4marZQ/812BQzHevxcBwo74=</ds:DigestValue>          HUELLA del documento para ser firmada
</ds:Reference>
</ds:SignedInfo>
<ds:SignatureValue>K9uOnnKciVVDUdntEMmYExNx+Kw/zIE20Oy1c+ZccfoIk+UJVMbPZhrZNrypCaHy1qIzT0veQTIY
  ULRkk5gBdpEsnM0tXnLWGmktHxkKOeLeuhoR5jjM/R76L5j0JlQqKilvrN2IzV0MVU3EmxArhfj fw8qQtnJMcfPHYkuLaY=</ds:SignatureValue>
- <ds:KeyInfo>
+ <ds:X509Data>
- <ds:KeyValue>          Parametro de Firma : Modulo SHA1withRSAEncryption
- <ds:RSAKeyValue>
  <ds:Modulus>0gBXsCOB+uKZ8nyF5J9bNXZZgWwR4Hdv1TBkttkHDFUEwG7xb8BM4N4KcJe+9D5KI2NVc3PRCa82
    CLhMneq/fSm3L9vr6p24gwSioteBde+87FDyMOOxPVxSHYJ75oVFMSMxJNv8b/ctD+T9lqLtV6sd biOfWU/qZnWpzMUlzc0=</ds:Modulus>
  <ds:Exponent>AQAB</ds:Exponent>
</ds:RSAKeyValue>
</ds:KeyValue>
</ds:KeyInfo>
</ds:Signature>
</soapenv:Header>
- <soapenv:Body Id="MsgBody">
- <Peticion xmlns="http://www.map.es/scsp/esquemas/V2/peticion">

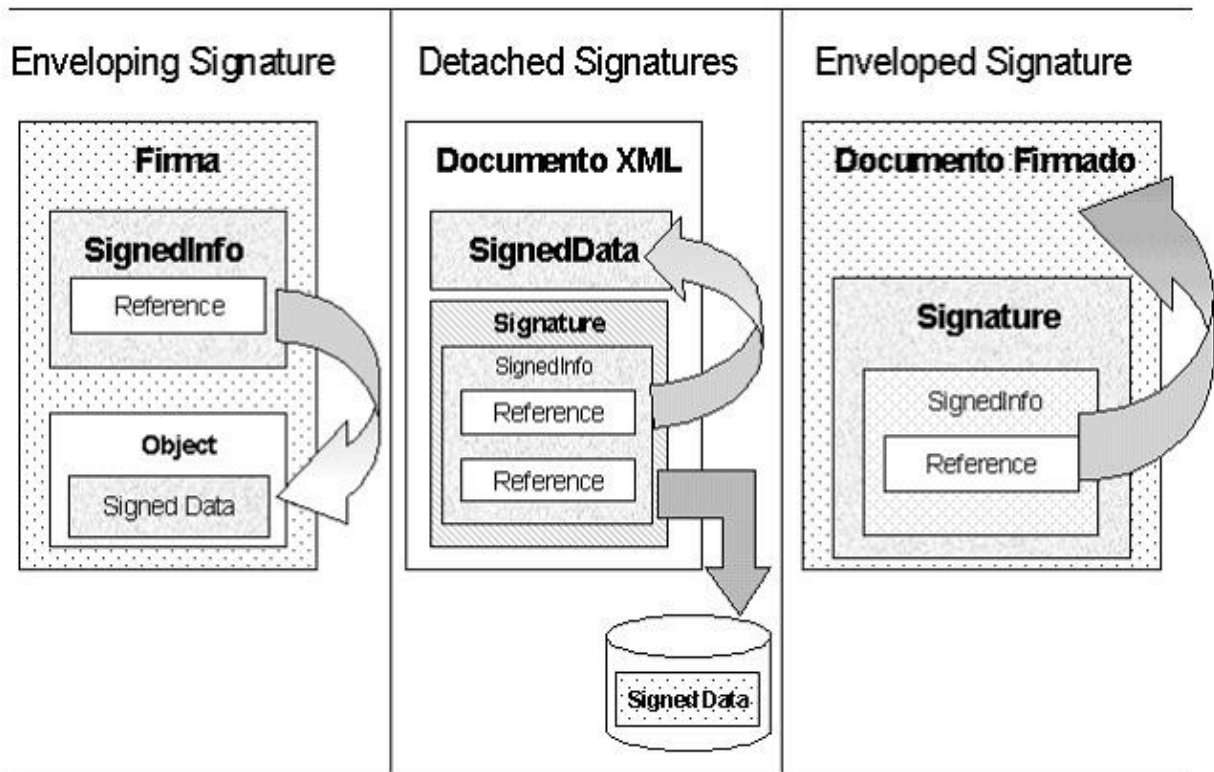
```

Figura 4.- Firma Enveloped de todo el Body de un mensaje XML

1.2. Escenarios de Utilización de la Firma Digital en XML

En relación con la situación de los datos que se van a firmar con respecto a su firma podemos tener la siguiente clasificación:

1. **Enveloping Signature:** La firma XML envuelve al contenido que se firma.
2. **Detached Signature:** El objeto que es firmado está separado de la firma XML.
3. **Enveloped Signature:** El contenido que se desea firmar engloba a la firma.



2. XAdES

XAdES:XML Advanced Electronic Signatures (Firma electrónica avanzada XML) es un conjunto de extensiones a las recomendaciones [XML-DSig](#) haciéndolas adecuadas para la firma electrónica avanzada.

Mientras que [XML-DSig](#) es un entorno general para firmar digitalmente documentos [XML](#), XAdES especifica perfiles precisos de [XML-DSig](#) para ser usados con **firma electrónica reconocida** con el sentido de la directiva 1999/93/EC de la Unión Europea. Un beneficio importante de XAdES es que los documentos firmados electrónicamente pueden seguir siendo válidos durante largos periodos de tiempo, incluso aunque los algoritmos criptográficos de firma hayan sido reventados.

- RFC 3126 “Electronic Signature Formats for long term electronic signatures” sept-2001 se describen las diferentes variantes de firma, con inclusión de elementos como sellos de tiempo e información de validación. Trasposición de la **norma ETSI TS 101 733 v.1.2.2 (CADES)**
- Evolucionado hasta la versión TS-101 733 v.2.2.1 → actualizar la RFC 5126.
- Marzo de 2008 → **RFC 5126 “CMS Advanced Electronic Signatures (CADES)”**.
- **XAdES** → Equivalente a CADES en XML Norma **TS-101903 v.1.3.2**
- Variantes de firma electrónica recomendadas en **facturación electrónica** → **CWA 15579**

- Formato **PAdES (PDF Advanced Electronic Signatures)**, según especificación técnica ETSI TS 102 778-3, versión 1.1.2. La firma está incluida en el estándar ISO PDF. Sólo se pueden firmar documentos PDF.
- **PDF / A** es una versión ISO del estándar de formato de documento portable (PDF) especializado para la preservación digital de documentos electrónicos .
- **PDF / A** difiere de PDF eliminando las características inadecuadas para archivado a largo plazo, como el enlace de fuentes (en oposición a la incrustación de fuentes)
- Los requisitos de ISO para los visores de archivos PDF/A incluyen directrices para la gestión de color, soporte las fuentes incrustadas (embebidas), y una interfaz de usuario para la lectura incorporado anotaciones .
- **PDF/A-1** se basa en el formato PDF versión 1.4 de referencia de Adobe Systems Inc. (implementado en Adobe Acrobat 5 y versiones más recientes) y se define por la norma ISO 19005-1:2005, un estándar ISO que se publicó el 01 de octubre 2005 : Gestión de documentos - Formato de archivo electrónico de documentos para la conservación a largo plazo - Parte 1: Uso de PDF 1.4 (PDF/A-1)
- **PDF/A-2** se basa en la ISO 32000-1 - PDF 1.7 y es definido por la norma ISO 19005-2:2011, publicada el 20 de junio de 2011 bajo el nombre de gestión de documentos oficiales - en formato electrónico el archivo de documentos para conservación a largo plazo - Parte 2: Uso de ISO 32000-1 (PDF/A-2). [2] PDF/A-2 es un estándar muy reciente y no se utiliza ampliamente.
- El sellado de tiempo (Timestamping) RFC 3161 es un mecanismo on-line que permite demostrar que una serie de datos han existido y no han sido alterados desde un instante específico en el tiempo. Una Autoridad de Sellado de Tiempo actúa como tercera parte de confianza testificando la existencia de dichos datos electrónicos en una fecha y hora concretos. XAdES emplea sellado de tiempo.

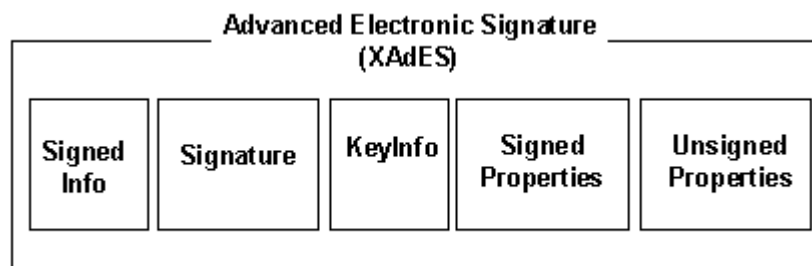


Figura 5.- Perfil Básico XAdES

Perfiles:

XAdES define seis/siete perfiles (formas) según el nivel de protección ofrecido. Cada perfil incluye y extiende al previo:

- **XAdES-BES**: forma básica que simplemente cumple los requisitos legales de la Directiva para firma electrónica avanzada (firma avanzada y/o reconocida). Para que una firma avanzada se considere como firma reconocida y de esta forma tenga la misma validez que la firma manuscrita debe realizarse con un dispositivo seguro de creación de firma (DSCF), para lo cual el dispositivo debe cumplir con la normativa EN-14890:1-2009.

XAdES-EPES, hace referencia a la política de firma, donde la política de firma es un documento con las normas de creación y validación de la firma. Desde el punto de vista de longevidad es equivalente a Xades-B

- **XAdES-T (timestamp)**: añade un campo de sellado de tiempo (firma con marca del momento en el que se realizó la firma).
- **XAdES-C (complete)**: añade referencias a datos de verificación (respuestas OCSP y CRL) de los documentos firmados para permitir verificación y validación off-line en el futuro. Los datos de verificación no están incluidos en la firma, sino que están guardados en otro lugar.
- **XAdES-X (extended)**: se utiliza cuando es necesario implantar una salvaguarda ante la posibilidad de que la CA de la cadena de certificación se vea comprometida en el futuro. XAdES-X aplica sellos de tiempo a los datos necesarios para garantizar que la firma es válida: la firma electrónica, el sellado de tiempo de la firma electrónica y las referencias introducidas por XAdES-C.

- **XAdES-X-L** (*extended long-term*): se utiliza cuando la cadena de certificación y los datos de validación no se guardan en un lugar seguro en el tiempo. Consiste en **añadir la cadena de certificación y la información de validación a la firma (CRL o respuesta OCSP)**, lo que permite la verificación en el futuro incluso si las fuentes originales no estuvieran ya disponibles (**firma validada**).
- **XAdES-A** (*archival*): se utiliza para garantizar la validez de la firma global en el tiempo, ya que los avances tecnológicos comprometen la seguridad de los algoritmos criptográficos empleados. Consiste en aplicar timestamping periódico de todos los elementos que puedan verse comprometidos durante un periodo largo de almacenamiento (firma longeva).
 - Formatos de firma electrónica de contenido según se especifica en la política de firma AGE.
 - Atendiendo a la NTI de Catálogo de estándares, serán: (**El perfil mínimo será «-EPES»**)
 - **a) XAdES (XML Advanced Electronic Signatures)**, según la especificación técnica ETSI TS 101 903, versión 1.2.2 y versión 1.3.2.
 - **b) CADES (CMS Advanced Electronic Signatures)**, según la especificación técnica ETSI TS 101 733, versión 1.6.3 y versión 1.7.4.
 - **c) PAdES (PDF Advanced Electronic Signatures)**, según la especificación técnica ETSI TS 102 778-3.
- El formato de firma → metadato mínimo obligatorio definido en la NTI de Documento electrónico 'Tipo de firma'
- Podrá tomar los valores:
 - ✓ XAdES internally detached signature.
 - ✓ XAdES enveloped signature.
 - ✓ CADES detached/explicit signature.
 - ✓ CADES attached/implicit signature.
 - ✓ PAdES.
- Algoritmos de generación de hash, codificación en base64, firma, normalización y transformación definidos en los estándares
 - ✓ XML-DSig (XML Digital Signature)
 - ✓ CMS (Cryptographic Message Syntax).

Nuevos tipos de firma Baseline

La normativa de desarrollo del Reglamento (UE) nº 910/2014 (eIDAS) incluye la definición de los **nuevos tipos de firma Baseline**. Estos tipos son equivalentes a los formatos tradicionales siempre y cuando las firmas incluyan una serie de requisitos determinados.

El nuevo formato representa un perfil más genérico y se utiliza para garantizar la interoperabilidad transfronteriza de las firmas electrónicas en el contexto de la Directiva 2006/123/CE del Parlamento Europeo y del Consejo del 12 de diciembre de 2006 relativo a los servicios en el mercado interior.

El cambio normativo viene refrendado en el Reglamento (UE) nº 910/2014, y más concretamente en la Decisión de Ejecución (UE) 2015/1506 de la Comisión de 8 de septiembre de 2015 por la que se establecen las especificaciones relativas a los formatos de las firmas electrónicas avanzadas y los sellos avanzados que deben reconocer los organismos del sector público. En dicha Decisión de Ejecución se indica en los artículos 1 y 3 respectivamente:

(1) Los Estados miembros que requieran una firma electrónica avanzada o una firma electrónica avanzada basada en un certificado cualificado como se prevé en el artículo 27, apartados 1 y 2, del Reglamento (UE) no 910/2014, reconocerán la firma electrónica avanzada XML, CMS o PDF en el nivel de conformidad B, T o LT o con un contenedor con firma asociada donde las firmas cumplan las especificaciones técnicas que figuran en el anexo.

(3) Los Estados miembros que requieran un sello electrónico avanzado o un sello electrónico avanzado basado en un certificado cualificado como se prevé en el artículo 37, apartados 1 y 2, del Reglamento (UE) no 910/2014 reconocerán el sello electrónico avanzado XML, CMS o PDF en el nivel de conformidad B, T o LT o con un contenedor con sello asociado que cumpla las especificaciones técnicas que figuran en el anexo.

Y en cuyo anexo se incluye la lista de especificaciones técnicas para las firmas electrónicas avanzadas XML, CMS o PDF y el contenedor con firma/sello asociada/o:

- Perfil de base XAdES (ETSI TS 103171 v2.1.1).
- Perfil de base CAdES (ETSI TS 103173 v2.2.1).
- Perfil de base PAdES (ETSI TS 103172 v2.2.2).
- Perfil de base del contenedor (ETSI TS 103174 v2.2.1).

A modo informativo, se establecen las siguientes equivalencias entre los formatos tradicionales y los nuevos formatos 'Baseline':

CAdES-BES/-EPES	CAdES B-Level
CAdES-T	CAdES T-Level
XAdES-BES/-EPES	XAdES B-Level
XAdES-T	XAdES T-Level
XAdES-X-L	XAdES LT-Level
XAdES-A	XAdES LTA-Level
PAdES-BES/-EPES	PAdES B-Level
PAdES-LTV	PAdES T-Level/LT-Level/LTA-Level

- Los perfiles Baseline son en muchos casos un subconjunto de los formatos tradicionales.

Firmas con múltiples usuarios

En el mundo del papel y de la firma manuscrita, un documento puede contener la firma de varias personas:

- En un caso, las firmas pueden tener el mismo peso o valor legal, por lo que da igual el orden en el que se estampen las firmas en el documento.
- Otro caso, es el que unas firmas sirven para refrendar o certificar otras firmas anteriores, por lo que el orden en el que se estampan las firmas es importante.

El equivalente a esas firmas en el mundo electrónico son las firmas múltiples. Atendiendo al criterio del número de firmantes podemos tener:

- **Firmas simples.** Son las firmas básicas que contienen la firma de un solo firmante.
- **Co-firma o firma en línea.** Es la firma múltiple en la que todos los firmantes están al mismo nivel y en la que no importa el orden en el que se firma. La co-firma se utiliza en la firma de documentos que son resultados de reuniones, conferencias o comités.
- **Contra-firma o firma en cascada.** Firma múltiple en la que el orden en el que se firma es importante, ya que cada firma debe refrendar o certificar la firma del firmante anterior. La contra-firma se utiliza especialmente en aplicaciones como los **PortaFirmas**, en los que un documento debe seguir **una línea específica a través de varios firmantes** hasta que todo el proceso es aprobado.

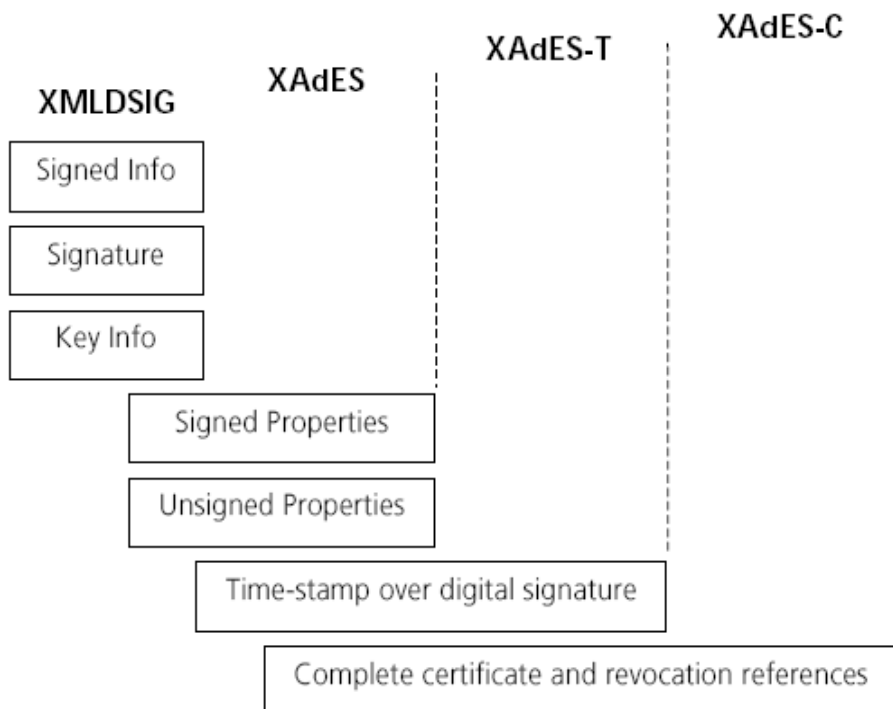
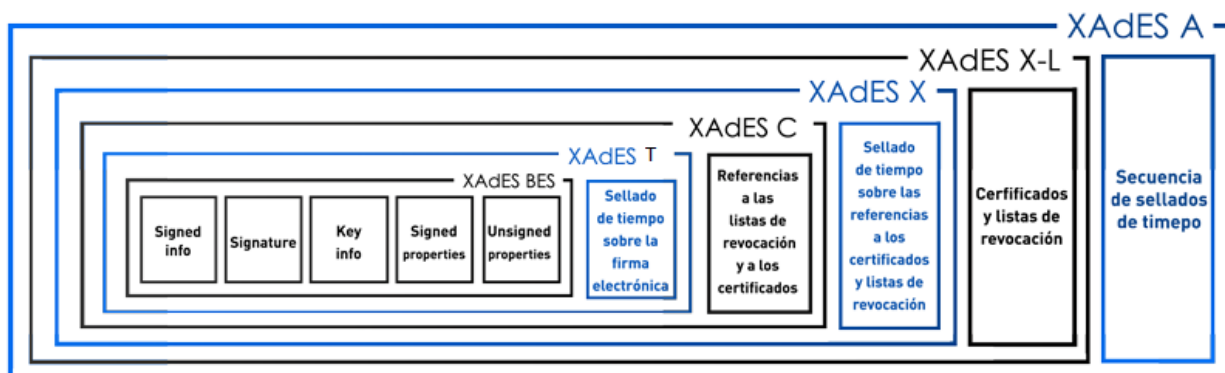
La aplicación de firma AutoFirma permite los tres tipos de firma. El usuario puede configurar el tipo de firma múltiple que desea realizar.

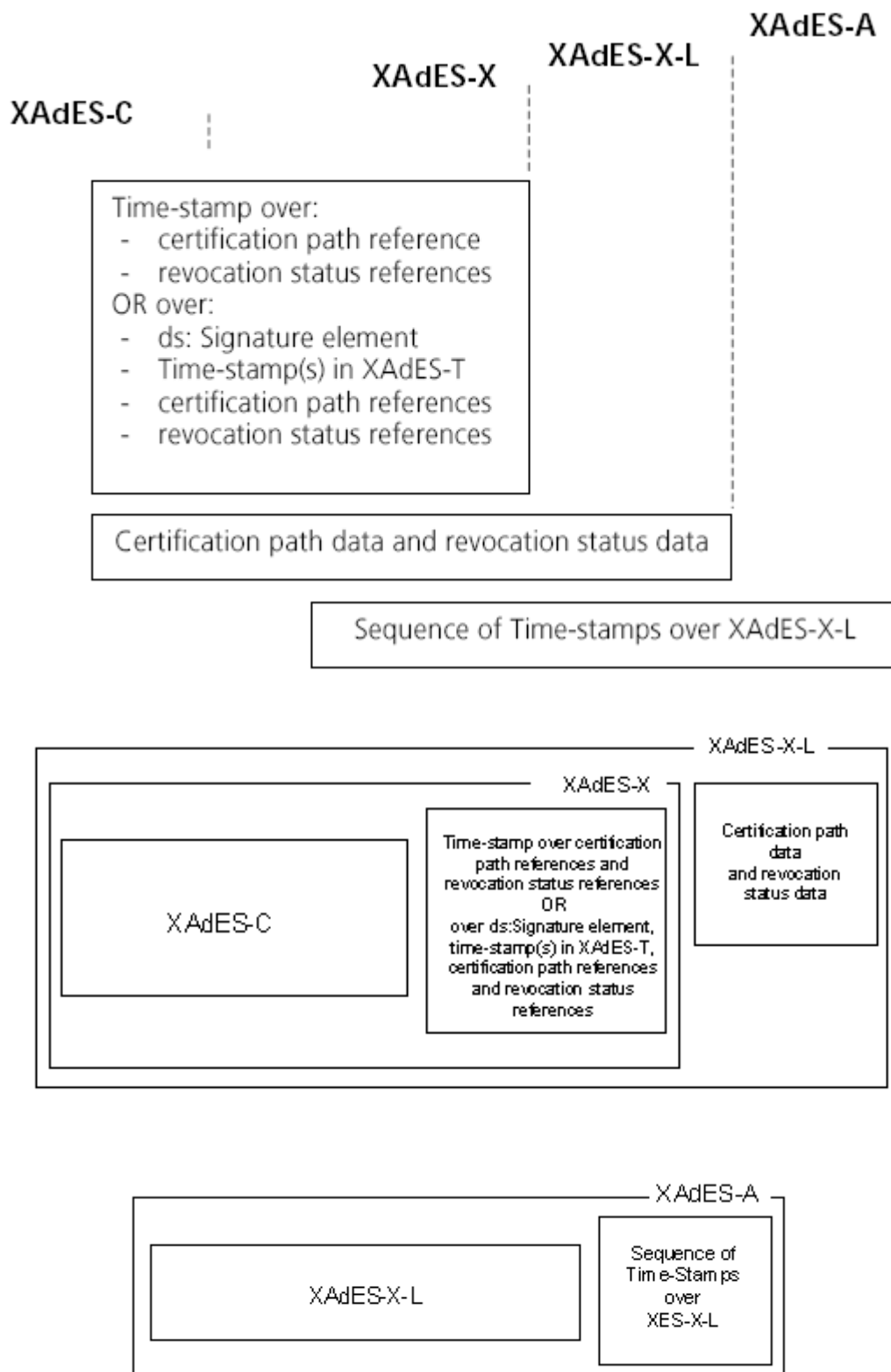
La aplicación FirmaFácil automáticamente selecciona la co-firma cuando se le presenta para firmar un documento firmado previamente.

Ejemplos y documentación de ejemplo:

[Factura Electrónica - Políticas de firma electrónica](#)

<https://www.facturae.gob.es/formato/Paginas/politicas-firma-electronica.aspx>





2.1. Validación Firma XAdES¹

Una firma electrónica avanzada de tipo XAdES-T sin una asociación específica a ninguna política de firma concreta, aún verificando con éxito el formato de la firma y su integridad,

¹ Los comentarios e ilustraciones hacen referencia a CADES, en lugar de a XAdES aunque son igualmente válidos. XAdES es la versión "XML de CADES"

la evaluación de la validez de dicha firma electrónica según la norma ETSI TS 101 903 v1.3.2 da como resultado Validación incompleta de la firma.

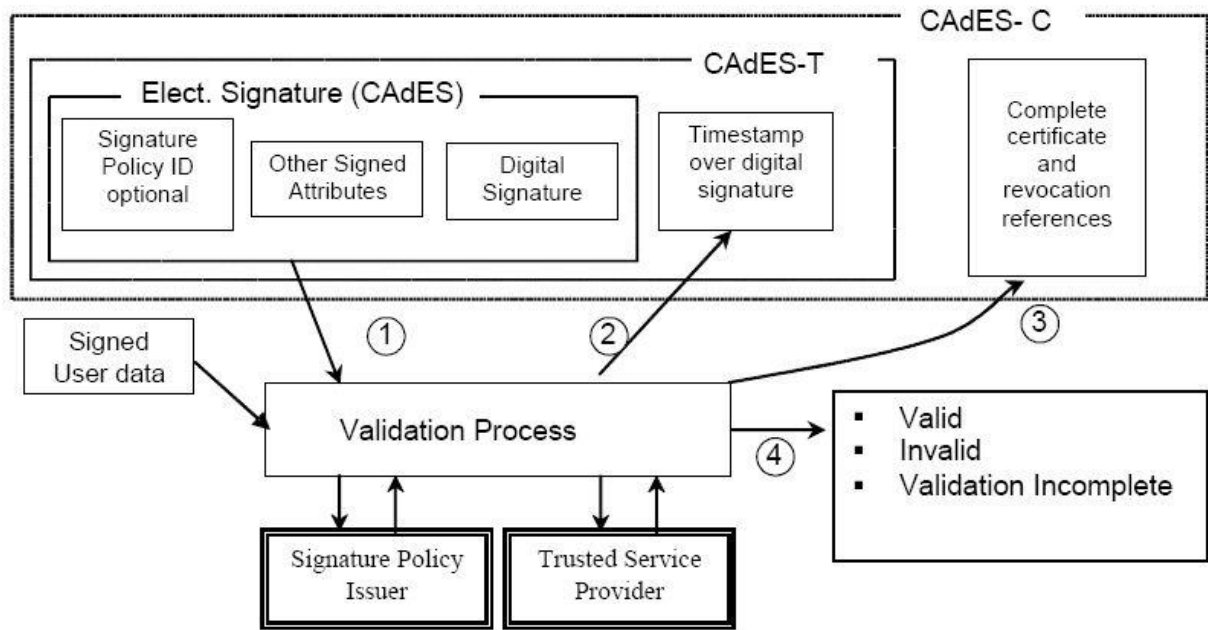


Figure B.6: Illustration of a CAdES validation sequence

Después de la recepción de la Firma Electrónica (Cades/xades) del firmante (1), el valor de firma digital puede ser controlado; el proceso de validación incluirá, como mínimo, añadir un sello de tiempo (2), a menos que el firmante ya haya proporcionado uno que sea de la confianza del verificador de la firma. El proceso de validación también podrá validar la firma electrónica, usando los datos adicionales (por ejemplo, certificados, CRL's, etc) proporcionados por los proveedores de servicios de certificación. En su caso, el proceso de validación también tendrá que ajustarse a los **requisitos especificados en la política de firma**.

Si el proceso de validación de la la firma es validación incompleta, la salida de esta etapa es Cades-T. Para determinar la validez como válido o no válido y comunicárselo al usuario (4) todos los datos adicionales necesarios para validar la Cades-C, deben estar disponibles (por ejemplo, la información completa del certificado y de la revocación).

Una vez que los datos necesarios para completar la validación de los datos de referencia (Cades-C) están disponibles, el proceso de validación puede:

- ✚ obtener todos los certificados adicionales que sean necesarios y la información del estado de revocación;
- ✚ completar todos los controles de validación en la ES, mediante el certificado completo de la información y la revocación (en caso de que un sello de tiempo no esté presente, puede ser añadido en la misma fase que combinando el proceso Cades-T y C);
- ✚ registro completo del certificado y de las referencias de revocación (3);
- ✚ indicar el estado de validez para el usuario (4).

Al mismo tiempo que el proceso de validación crea la Firma Cades-C, el proceso de validación puede proporcionar y / o registrar los valores de los certificados y del estado de revocación utilizados en Cades-C, llamado Cades-X Largo (5)

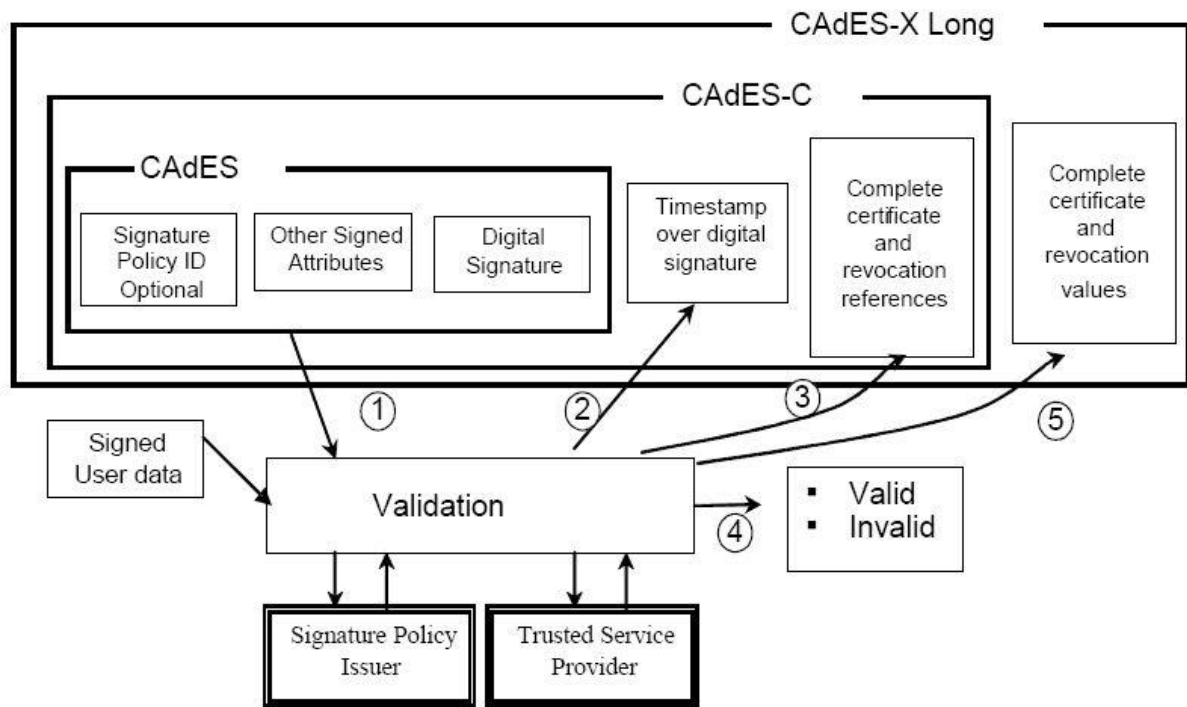
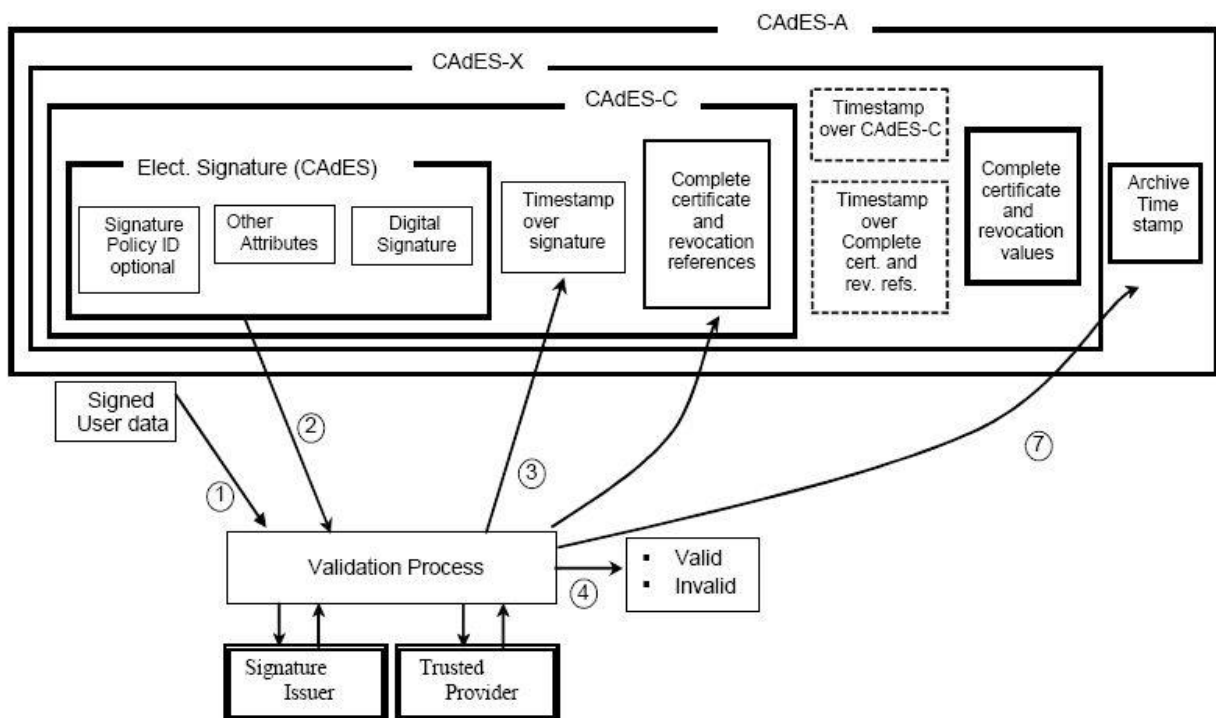


Figure B.7: Illustration a CADES validation sequence with CADES-X Long

2.2. Validación Firma XAdES-A

Antes de que los algoritmos utilizados en cualquiera de las firmas electrónicas se conviertan o sea probable que sean comprometidos o se conviertan en vulnerables en el futuro, puede ser necesario el sello de tiempo de toda la firma electrónica, incluyendo todos los valores de la validación y de los datos del usuario como una Firma Electrónica con archivo de validación de Datos (Cades-A) (7)



3. Ejemplos Firma y cifrado

XML Encryption

Objetivo: proteger información que se envía del acceso no autorizado por terceras partes

Permite cifrar:

- ✚ Un documento XML completo
- ✚ Un elemento de un documento XML
- ✚ El contenido de un elemento
- ✚ Datos textuales que no son XML
- ✚ Contenidos ya cifrados

Componentes de XML Encryption

El elemento EncryptedData, que es el que reemplaza al elemento cifrado consta de:

- ✚ EncryptionMethod
- ✚ KeyInfo
- ✚ CipherData

Se puede cifrar un valor, Number, un nodo <CreditCard> o todo el documento.

-

```
<?xml version='1.0'?>
<PaymentInfo xmlns='http://example.org/paymentv2'>
  <Name>Homer Simpson</Name>
  <CreditCard Limit='500' Currency='USD'>
    <Number>4019 2445 0277 5567</Number>
    <Issuer>Banco por Internet de Springfield</Issuer>
    <Expiration>12/02</Expiration>
  </CreditCard>
</PaymentInfo>
```



```
<?xml version='1.0'?>
<PaymentInfo xmlns='http://example.org/paymentv2'>
  <Name>Homer Simpson</Name>
  <CreditCard Limit='500' Currency='USD'>
    <Number>
      <EncryptedData Type='http://www.w3.org/2001/04/xmlenc#Content'
        xmlns='http://www.w3.org/2001/04/xmlenc#'>
        <CipherData><CipherValue>A23...</CipherValue></CipherData>
      </EncryptedData>
    </Number>
    <Issuer>Banco por Internet de Springfield</Issuer>
    <Expiration>12/02</Expiration>
  </CreditCard>
</PaymentInfo>
```

Figura 6.- cifrado de un valor etiquetado



```
<?xml version='1.0'?>
<PaymentInfo xmlns='http://example.org/paymentv2'>
  <Name>Homer Simpson</Name>
  <CreditCard Limit='500' Currency='USD'>
    <Number>4019 2445 0277 5567</Number>
    <Issuer>Banco por Internet de Springfield</Issuer>
    <Expiration>12/02</Expiration>
  </CreditCard>
</PaymentInfo>
```

↓

```
<?xml version='1.0'?>
<PaymentInfo xmlns='http://example.org/paymentv2'>
  <Name>Homer Simpson</Name>
  <EncryptedData Type='http://www.w3.org/2001/04/xmlenc#Element'
    xmlns='http://www.w3.org/2001/04/xmlenc#'>
    <CipherData><CipherValue>C56...</CipherValue></CipherData>
  </EncryptedData>
</PaymentInfo>
```

EncryptedData reemplaza a lo cifrado

Figura 7.- cifrado de un nodo etiquetado



```
<?xml version='1.0'?>
<PaymentInfo xmlns='http://example.org/paymentv2'>
  <Name>Homer Simpson</Name>
  <CreditCard Limit='500' Currency='USD'>
    <Number>4019 2445 0277 5567</Number>
    <Issuer>Banco por Internet de Springfield</Issuer>
    <Expiration>12/02</Expiration>
  </CreditCard>
</PaymentInfo>
```

↓

```
<?xml version='1.0'?>
  <EncryptedData
    MimeType='text/xml'
    xmlns='http://www.w3.org/2001/04/xmlenc#'>
    <CipherData><CipherValue>B45...</CipherValue></CipherData>
  </EncryptedData>
```

Figura 8.- cifrado de todo el documento

4. WS-Security

WS-Security: protocolo de comunicaciones que suministra un medio para aplicar seguridad a los [Servicios Web](#).

Originalmente desarrollado por [IBM](#), [Microsoft](#), y [VeriSign](#), el protocolo es ahora llamado oficialmente WSS y está desarrollado por un comité en [Oasis-Open](#). Abril de 2004 WS 1.0 publicado por [Oasis-Open](#). En 2006 fue publicada la versión 1.1.

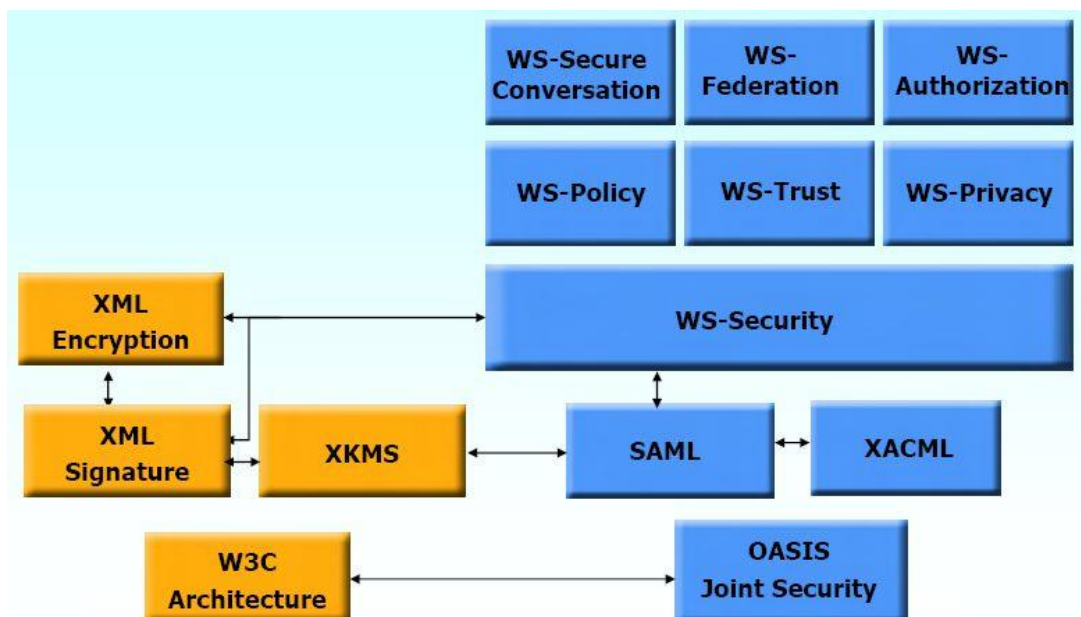
El protocolo contiene especificaciones sobre cómo debe garantizarse la integridad y seguridad en mensajería de [Servicios Web](#). El protocolo WSS incluye detalles en el uso de [SAML](#) y [Kerberos](#), y formatos de certificado tales como [X.509](#).

La [Integridad de datos](#) y [confidencialidad](#) pueden garantizarse sobre [Servicios Web](#) a través del uso de la [Transport Layer Security](#) (TLS), por ejemplo enviando mensajes sobre [HTTPS](#). Esto puede reducir significativamente la sobrecarga, la parte negativa es que no asegura la seguridad extremo a extremo, sino que solo asegura la seguridad punto a punto.

WS-Security incorpora características de seguridad en el encabezado de un mensaje [SOAP](#), trabajando en la capa aplicación. Así asegura seguridad extremo a extremo.

Las siguientes **especificaciones** borrador están asociadas con WS-Security:

- ✚ [WS-SecureConversation](#)
- ✚ [WS-Federation](#)
- ✚ [WS-Authorisation](#)
- ✚ [WS-Policy](#)
- ✚ [WS-Trust](#)
- ✚ [WS-Privacy](#)



Cada una de las principales características se resume a continuación:

- ♦ **WS-Security** representa un conjunto de especificaciones que describen cómo firmar y cifrar las cabeceras de los mensajes SOAP, así como adjuntar tokens de seguridad, incluidos binarios como certificados X.509 y tickets de Kerberos, a los mensajes.
- ♦ **WS-Policy** es una recomendación del [W3C](#) desde Septiembre de 2007. La especificación WS-Policy esta formada por un conjunto de especificaciones que

describen las capacidades y restricciones asociadas a determinados servicios web. Esta especificación permite a los programadores de servicios web anunciar sus políticas relativas a seguridad, calidad de servicio, etc. y a los clientes de servicios web especificar sus requisitos de calidad de servicio, seguridad, latencia, etc..

- ♦ **WS-Trust** representa un conjunto de especificaciones que describen un marco de confianza que permite a los modelos de servicios web interactuar con seguridad mediante la solicitud, expedición y el intercambio de tokens de seguridad.
- ♦ **WS-SecureConversation** representa un conjunto de especificaciones que describen cómo administrar la autenticación de mensajes y los intercambios entre las partes, incluyendo el contexto de seguridad y los intercambios y el establecimiento de claves de sesión.
- ♦ **WS-Federation** representa un conjunto de especificaciones que describen cómo administrar las relaciones de confianza en un entorno federado heterogéneo, incluyendo el soporte a las identidades federadas, el intercambio de atributos y la gestión de los seudónimos.
- ♦ **WS-Privacy** representa un conjunto de especificaciones que describen el modelo de preferencias y declaraciones de privacidad que se deben aplicar en las peticiones de servicios Web.
- ♦ **WS-Authorization** representa un conjunto de especificaciones que describen la forma de gestionar datos y políticas de autorización.

Otras especificaciones de servicios Web que complementan a las anteriores:

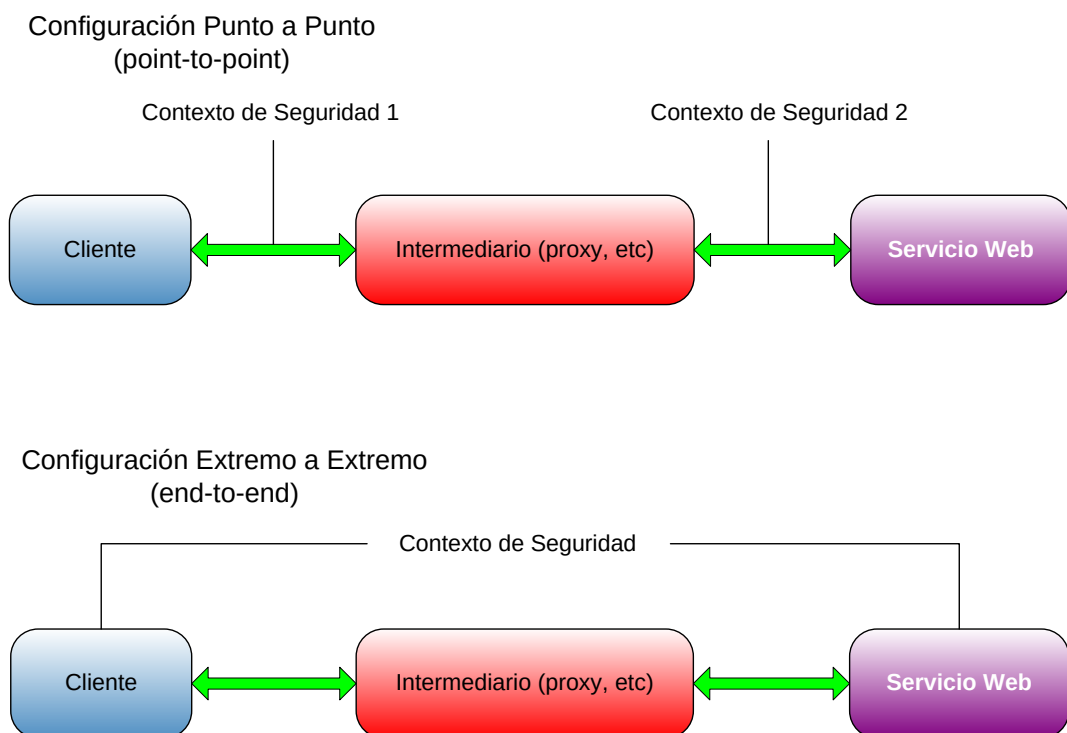
- **WS-Addressing** representa un conjunto de especificaciones que describen cómo gestionar la identificación y el tratamiento de la información para los mensajes.
- **WS-MetadataExchange** representa un conjunto de especificaciones que describen cómo intercambiar metadatos, tales como información de políticas de servicios (WS-Policy) y descriptores (WSDL) entre los servicios y puntos finales (endpoints).
- **WS-ReliableMessaging** representa un conjunto de especificaciones que describen la manera de garantizar la entrega fiable de mensajes en presencia de redes poco fiables.
- **WS-Transactions** y **WS-Coordination** representa un conjunto de especificaciones que describen cómo habilitar las operaciones de transacción, como parte de los intercambios de mensajes SOAP.

La única especificación a la que dedicaremos más atención será WS-Security ya que supone los cimientos de toda la seguridad en servicios Web. El resto de las especificaciones añaden nuevas definiciones y extensiones a esta; desde WS-Trust, pasando por WS-Policy, hasta WS-Federation, que representa la unificación global de toda la Seguridad en Servicios WEB.

WS-Security

La especificación de seguridad de Servicios Web (WS-Security) proporciona un conjunto de mecanismos para facilitar el intercambio seguro de mensajes SOAP.

En concreto, WS-Security describe las mejoras a los actuales mensajes SOAP para proporcionar **calidad en la protección** mediante la aplicación de la **integridad**, **confidencialidad** y **autenticación** de mensajes SOAP. Estos mecanismos básicos se pueden combinar con otros protocolos de servicios Web para dar cabida a la construcción de una amplia variedad de modelos de seguridad usando las diferentes tecnologías criptográficas disponibles actualmente. WS-Security está diseñada para garantizar seguridad extremo a extremo, mejorando sustancialmente la configuración punto a punto donde existen zonas vulnerables.



WS-Security también proporciona un mecanismo de propósito general para asociar mensajes con tokens de seguridad. Al contrario que en otras implementaciones, no es necesario el uso de un tipo específico de token. WS-Security está diseñada para ser extensible, soportando múltiples formatos de token de seguridad y así proporcionar una gran variedad de mecanismos de autenticación y autorización. Por ejemplo, un solicitante puede presentar una prueba de identidad y firmar el **reclamo o aserción (token de seguridad)** que tiene un propósito particular, el acceso. El servicio Web, cuando reciba este mensaje, puede determinar qué tipo de confianza se deposita en el reclamo o aserción.

Además, WS-Security describe cómo codificar en binario tokens de seguridad y adjuntarlos a los mensajes SOAP. En concreto, la especificación WS-Security describe cómo codificar certificados X.509 y tickets de Kerberos, así como la manera de incluir claves cifradas opacas como una muestra de diferentes tipos de modos binarios. Los tickets Kerberos y los certificados X.509 se utilizan actualmente por los desarrolladores para añadir mecanismos de autenticación en muchas aplicaciones web. WS-Security también incluye mecanismos de extensibilidad que se pueden utilizar para describir con más detalle las credenciales que se incluyen con un mensaje.

La Firma XML (XMLDSig en todas sus variantes), garante de la integridad, y los tokens de seguridad garantizan que los mensajes se han originado a partir del remitente y no fueron modificados en tránsito. Del mismo modo, aprovecha el concepto de confidencialidad para mantener cifradas ciertas partes de un mensaje SOAP.

XKMS XML Key Management Specification (Especificación XML para manejo de claves)

Objetivo: Ocultar al usuario la complejidad subyacente en una PKI. Consta de 2 partes:

Información de clave pública

- X-KISS (XML Key Information Service Specification)
- Buscar la clave pública de alguien y comprobar si es buena
- Procesar el campo KeyInfo contenido en las firmas digitales

Registro de clave pública

- X-KRSS (XML key Registration Service Specification)
- Especifica cómo se registra, revoca y recupera información de claves Públicas.
- La generación de claves públicas se puede realizar por el cliente o al momento del registro en el servidor

SAML

SAML (Security Assertion Markup Language) permite compartir información de autenticación entre aplicaciones. Se basa en autoridades que emiten aserciones. Transmite varios tipos de aserciones:

-  Aserción de autenticación
-  Aserción de atributo

XACML

XACML (XML Access Control Markup Language) permite expresar políticas de control de acceso. Codifica en reglas XML expresiones del tipo: Una persona puede leer un informe si es el propio paciente

XrML

XrML (eXtensible Rights Markup Language)

Permite expresar reglas sobre derechos

Codifica expresiones del tipo: Un consumidor puede ver una película 6 veces durante 15 días

XAdES, a XML Family Member

- XML Syntax (W3C, subset of SGML)
- XML Schema (W3C)
- XSL (XML Style sheet Language, W3C)
 - Xpath (XML Path Language, W3C)

- XSLT (XSL Transformations, W3C)
- XSL-FO (XSL Formatting Objects, W3C)

Web Services (W3C)

- SOAP (Simple Object Access Protocol, W3C)
- WSDL (Web Service description language, W3C)

XML Signature (W3C)

XML Encryption (W3C)

XKMS (XML Key Management Specifications, W3C)

- X-KISS (XML Key Information Service Specification, W3C)
- X-KRSS (XML Key Registration Service Specification, W3C)
- X-Bulk (Bulk Key Registration, W3C)

SAML (Security Assertion Markup Language, OASIS)

XACML (XML Access Control Language, OASIS)

5. Algoritmos Simétricos de Bloques

Tabla 1: Seguridad de algunos Algoritmos de Cifrado – ver notación debajo

Name	Version	Author(s)	Block	Key	Rounds	Attack(s)
DES	(77)	IBM/NSA	64	56	16	K:43/19/13 [M94]
	3-DES (77)	Diffie, Hellman	64	168	48	K:2/112/56
	2k3-DES (78)	Tuchmann	64	112	48	K:n/120-n/n [OW91] , C:56/56/56/ [M79]
FEAL-N	(87-90)	Miyaguchi, ..	64	128	N	K:2/./.(4), C:4/./.(8) [AO96]
RC2	(89)	Rivest	64	8-1024	18	C:64/64/./.(16) [KRRR98]
Khufu	(90)	Merkle	64	512	8s, s>1	C:52/./.(26) [BBS99]
Khafre	(90)	Merkle	64	64t, t>0	8s, s>1	C:52/./.(26) [BBS99]
IDEA	(91)	Lai, Massey, Murphy	64	128	8,5	C:64/112/32(4,5) [BBS99]
LOKI	(90)	Brown, Pieprzyk, Seberry	64	64	16	C:54/./.(14), K:62/./.(11)
	(91)	Brown, Kwan, Pieprzyk, Seberry	64	64	16	C:58/./.(13) [K94] , K:60/./.(11) [SF97]
SAFER	K (93)	Massey	64	64,128	6,10	C:45/./32(5) [KB96]
	SK (95)	Massey, Knudsen	64	40,64,128	8,10	?
Blowfish	(93)	Schneier	64	32-448	16	?
RC5	32/12/k (94)	Rivest	64	8s, s<256	12	C:54/./ [KM96]
	64/16/16 (94)	Rivest	128	8s, s<256	16	C:83/./ [KM96] , C:123/./.(24) [KM96]

CAST-128	(95)	Adams	64	40-128	12, 16	?
SHARK	(96)	Rijmen, Daemen, Preneel, Bosselaers, de Win	64	128	6	?
SQUARE	(97)	Daemen, Knudsen, Rijmen	128	128	8	CP:32/72/32(6) [DKR97]
MISTY	1 (97)	Matsui	64	128	8	?
	2 (97)	Matsui	64	128	12	?
ICE	(97)	Kwan	64	64	16	CP:62/62/30 [VRKR98]
Skipjack	(98)	NSA?	64	80	32	[BS98]
Rainbow	(98)	Lee, Kim	128	128	7	?
SMS4	(?)	?	128	128	?	?
Name	Version	Author(s)	Block	Key	Rounds	Attack(s)

Notacion de la tabla:

Name	Name of the block cipher
Version	Name (year) of version
Author(s)	Name of the designer(s)
Block	the block length in bits
Key	the key length in bits
Rounds	the number of rounds of the cipher
Attack(s)	K:a/b/c denotes that the best known plaintext attack requires 2^a plaintext/ciphertexts, has a workload of 2^b encryptions and requires 2^c words of memory. C:a/b/c denotes that the best chosen plaintext attack requires 2^a plaintext/ciphertexts, has a workload of 2^b encryptions and requires 2^c words of memory. A `.' means that this resource requirement is either negligible or unknown to us. (r): the number of rounds of the attack. If blank, r=Rounds [SA]: the paper describing the attack ?: No attacks known